

Digital Personal Data Protection (DPDP) Act 2023 Compliance Report

Audited Entity: **Paytm** (FinTech)

Report ID:	PL-AUD-202607271328
Audit Date:	July 27, 2026
Statutory Framework:	India DPDP Act 2023
Compliance Score:	18.7/100
Overall Risk level:	Critical Risk

1. Executive Summary

PolicyLens AI completed a comprehensive GRC assessment of Paytm's privacy policy under the DPDP Act 2023. The document scored 31.1/100, indicating a status of 'Critical Risk'. We identified 0 compliant pillars and 11 compliance gaps. The primary risks center on Grievance Redressal and Consent. Review the recommendations below to establish technical controls and legal language adjustments.

Compliance Score	Vulnerability Risk	Rule Checks Passed	Rule Violations	AI Confidence
18.7%	81.3%	0	11	96%

2. DPDP Pillar Heatmap Analysis

The platform audited the policy against the seven structural pillars of the DPDP Act 2023, scoring each and identifying critical gaps.

DPDP Pillar	Audited Score	Compliance Level	Primary Requirement
Consent	■ FAIL (20)	FAIL	Explicit, granular, and withdrawable consent.
Notice	■ PARTIAL (50)	PARTIAL	Purpose and rights disclosure presented in notice.
Data Principal Rights	■ FAIL (20)	FAIL	Enable right to access, correction, and erasure.
Children's Data	■ FAIL (20)	FAIL	Age verification and verifiable parental consent.
Data Fiduciary Obligations	■ PARTIAL (50)	PARTIAL	Accuracy control, retention limits, security guards.
Grievance Redressal	■ FAIL (20)	FAIL	Publish Grievance Officer contacts & SLA response.
Cross Border Transfer	■ PARTIAL (50)	PARTIAL	Transfers compliant with federal blacklist/rules.

3. Detailed Risk Findings & Evidence

Traceable compliance violations, complete with the legal section breaches, extracted textual evidence, and recommendations.

Finding 1: Non-Compliant: Grievance Officer Designation

Pillar: Grievance Redressal | **Section:** Section 13 | **Severity:** High | **Confidence:** 95%

Gap Analysis: No designated Grievance Officer or Nodal Officer was found in the text. Under Section 13 of the DPDP Act 2023, data fiduciaries must publish contact details of a Grievance Officer.

Policy Evidence: *No clause or reference found in document.*

Legal Liability: Contravention of Section 13. Statutory penalty cap: Up to ■50 Crore under general statutory breach provisions.

Business Impact: Increases liability and risk of regulatory enforcement action.

Legal Recommendation	Technical Action	Business Action
Update policy terms to incorporate explicit statutory disclosures for Section 13.	Implement technical controls in user profile backend and database.	Train operations and customer support teams on compliance SLAs.

Finding 2: Non-Compliant: Contact Email Disclosure

Pillar: Grievance Redressal | **Section:** Section 13 | **Severity:** Medium | **Confidence:** 95%

Gap Analysis: No contact email address was found. Data fiduciaries are required to provide a clear channel of contact for complaints.

Policy Evidence: No clause or reference found in document.

Legal Liability: Contravention of Section 13. Statutory penalty cap: Up to ₹50 Crore under DPDP Act statutory penalty schedule.

Business Impact: Increases liability and risk of regulatory enforcement action.

Legal Recommendation	Technical Action	Business Action
Update policy terms to incorporate explicit statutory disclosures for Section 13.	Implement technical controls in user profile backend and database.	Train operations and customer support teams on compliance SLAs.

Finding 3: Non-Compliant: Consent Withdrawal Mechanism

Pillar: Consent | **Section:** Section 6(4) | **Severity:** High | **Confidence:** 95%

Gap Analysis: No explicit consent withdrawal mechanism was detected. Under DPDP Section 6(4), the Data Principal has the right to withdraw consent as easily as it was given.

Policy Evidence: No clause or reference found in document.

Legal Liability: Contravention of Section 6(4). Statutory penalty cap: Up to ₹50 Crore for non-compliance with withdrawable consent requirements under Section 6.

Business Impact: Increases liability and risk of regulatory enforcement action.

Legal Recommendation	Technical Action	Business Action
Update policy terms to incorporate explicit statutory disclosures for Section 6(4).	Implement technical controls in user profile backend and database.	Train operations and customer support teams on compliance SLAs.

Finding 4: Non-Compliant: Children's Data Protections

Pillar: Children's Data | Section: Section 9(1) | Severity: Critical | Confidence: 95%

Gap Analysis: Missing clear disclosures regarding children's data or parental consent. Section 9 of the DPDP Act requires parental/guardian consent and forbids tracking or targeted ads for children.

Policy Evidence: No clause or reference found in document.

Legal Liability: Contravention of Section 9(1). Statutory penalty cap: Up to ₹200 Crore for breaching obligations in relation to children under Section 9.

Business Impact: Increases liability and risk of regulatory enforcement action.

Legal Recommendation	Technical Action	Business Action
Update policy terms to incorporate explicit statutory disclosures for Section 9(1).	Implement technical controls in user profile backend and database.	Train operations and customer support teams on compliance SLAs.

Finding 5: Non-Compliant: Data Retention Disclosures

Pillar: Data Fiduciary Obligations | Section: Section 8(7) | Severity: Medium | Confidence: 95%

Gap Analysis: No clear data retention timelines or deletion triggers were found. Section 8(7) mandates that personal data must be erased once the purpose of collection is completed.

Policy Evidence: No clause or reference found in document.

Legal Liability: Contravention of Section 8(7). Statutory penalty cap: Up to ₹50 Crore under DPDP Act statutory penalty schedule.

Business Impact: Increases liability and risk of regulatory enforcement action.

Legal Recommendation	Technical Action	Business Action
Update policy terms to incorporate explicit statutory disclosures for Section 8(7).	Implement technical controls in user profile backend and database.	Train operations and customer support teams on compliance SLAs.

Finding 6: Non-Compliant: Cross-Border Transfer Disclosures

Pillar: Cross Border Transfer | Section: Section 16 | Severity: Medium | Confidence: 95%

Gap Analysis: No international data transfer disclosures were found. Fiduciaries must disclose cross-border processing locations under Section 16.

Policy Evidence: No clause or reference found in document.

Legal Liability: Contravention of Section 16. Statutory penalty cap: Up to ₹50 Crore under DPDP Act statutory penalty schedule.

Business Impact: Increases liability and risk of regulatory enforcement action.

Legal Recommendation	Technical Action	Business Action
Update policy terms to incorporate explicit statutory disclosures for Section 16.	Implement technical controls in user profile backend and database.	Train operations and customer support teams on compliance SLAs.

Finding 7: Non-Compliant: Notice of Purpose of Collection

Pillar: Notice | Section: Section 5 | Severity: Medium | Confidence: 95%

Gap Analysis: No explicit section explaining the purpose of personal data collection was found. Section 5 mandates presenting a clear notice specifying the personal data and the purpose.

Policy Evidence: No clause or reference found in document.

Legal Liability: Contravention of Section 5. Statutory penalty cap: Up to ₹50 Crore under statutory penalty provisions for notice non-compliance.

Business Impact: Increases liability and risk of regulatory enforcement action.

Legal Recommendation	Technical Action	Business Action
Update policy terms to incorporate explicit statutory disclosures for Section 5.	Implement technical controls in user profile backend and database.	Train operations and customer support teams on compliance SLAs.

Finding 8: Non-Compliant: Right to Access and Correction

Pillar: Data Principal Rights | Section: Section 11 | Severity: Medium | Confidence: 95%

Gap Analysis: Missing clear disclosures regarding data rectification or access. DPDP Sections 11 and 12 grant Data Principals the right to access and correct inaccurate or misleading personal data.

Policy Evidence: No clause or reference found in document.

Legal Liability: Contravention of Section 11. Statutory penalty cap: Up to ₹50 Crore under DPDP Act statutory penalty schedule.

Business Impact: Increases liability and risk of regulatory enforcement action.

Legal Recommendation	Technical Action	Business Action
Update policy terms to incorporate explicit statutory disclosures for Section 11.	Implement technical controls in user profile backend and database.	Train operations and customer support teams on compliance SLAs.

Finding 9: Non-Compliant: Right to Erasure (Deletion)

Pillar: Data Principal Rights | Section: Section 12 | Severity: High | Confidence: 95%

Gap Analysis: No explicit right to erasure or deletion was found. Section 12 grants Data Principals the right to request erasure of their personal data.

Policy Evidence: No clause or reference found in document.

Legal Liability: Contravention of Section 12. Statutory penalty cap: Up to ₹50 Crore under DPDP Act statutory penalty schedule.

Business Impact: Increases liability and risk of regulatory enforcement action.

Legal Recommendation	Technical Action	Business Action
Update policy terms to incorporate explicit statutory disclosures for Section 12.	Implement technical controls in user profile backend and database.	Train operations and customer support teams on compliance SLAs.

Finding 10: Non-Compliant: Security Safeguards Disclosure

Pillar: Security Safeguards | Section: Section 8(5) | Severity: Critical | Confidence: 95%

Gap Analysis: No explicit security safeguards disclosure found. Section 8(5) mandates that data fiduciaries implement reasonable security safeguards to prevent personal data breaches.

Policy Evidence: No clause or reference found in document.

Legal Liability: Contravention of Section 8(5). Statutory penalty cap: Up to ₹250 Crore for failing to observe reasonable security safeguards under Section 8(5).

Business Impact: Increases liability and risk of regulatory enforcement action.

Legal Recommendation	Technical Action	Business Action
Update policy terms to incorporate explicit statutory disclosures for Section 8(5).	Implement technical controls in user profile backend and database.	Train operations and customer support teams on compliance SLAs.

Finding 11: Non-Compliant: Data Breach Notification Obligation

Pillar: Data Breach Notification | Section: Section 8(6) | Severity: High | Confidence: 95%

Gap Analysis: Missing data breach notification procedures. Section 8(6) requires data fiduciaries to notify the Data Protection Board and affected Data Principals of any personal data breach.

Policy Evidence: No clause or reference found in document.

Legal Liability: Contravention of Section 8(6). Statutory penalty cap: Up to ₹150 Crore for failing to notify Data Protection Board or Data Principals of data breach under Section 8(6).

Business Impact: Increases liability and risk of regulatory enforcement action.

Legal Recommendation	Technical Action	Business Action
Update policy terms to incorporate explicit statutory disclosures for Section 8(6).	Implement technical controls in user profile backend and database.	Train operations and customer support teams on compliance SLAs.

4. Appendix & Regulatory Penalties

This audit report is generated automatically using hybrid deterministic parsing and advanced language understanding trained on the statutory clauses of India's Digital Personal Data Protection (DPDP) Act 2023. Compliance scores represent conformity with standard disclosure expectations but do not constitute formal legal counsel. For high-priority risks, we recommend consulting qualified cyber-lawyers in India prior to publishing revised privacy notices.